

## **TOSCANA DIAGNOSTICA S.r.l.**

Sistema di Gestione Integrato

### **REPORT DI AUDIT DOCUMENTALE** DEL SGI – AUDIT Q2 2026

Area 01 – Gestione del Sistema

| Codice                                | Revisione              | Data                                              | Pagine    |
|---------------------------------------|------------------------|---------------------------------------------------|-----------|
| <b>TD-SGI-RPT003_00</b>               | 00                     | 04/05/2026                                        | 25        |
| Redatto da                            | Approvato da           | Classificazione                                   | Stato     |
| RSGI / Lead Auditor (stile ISO 19011) | AD – Francesco Epifani | Riservato Alta Direzione + Enti di certificazione | In vigore |

| Responsabile del Documento | RSGI           | Emissione del Documento |
|----------------------------|----------------|-------------------------|
| Iacopo Cupelli             | Iacopo Cupelli | Francesco Epifani       |
| 04/05/2026                 | 04/05/2026     | 04/05/2026              |

**Toscana Diagnostica S.r.l.**

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.  
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

## 1. Scopo del Report

Il presente documento è il Report di Audit Documentale del SGI di Toscana Diagnostica – Audit Q2 2026 (rev 00 consolidata al 04/05/2026), il primo audit interno calendarizzato del 2026, condotto secondo i principi della norma ISO 19011:2018 con stile e rigore propri di un audit pre-certificazione di terza parte. Il Report è emesso contestualmente al Verbale dell'Audit TD-SGI-MOD214\_00 (in Area 10 Audit) e si configura come elemento istruttorio per gli audit di certificazione di prossima programmazione.

Il presente documento sostituisce e consolida le precedenti revisioni emesse durante il ciclo dell'audit (rev 00 del 29/04/2026; rev 01 e rev 02 del 30/04/2026; rev 00 consolidata del 30/04/2026) recependo: (a) le 44 nuove emissioni + 5 revisioni del periodo 28 aprile – 4 maggio 2026; (b) le chiusure per documenti esistenti già presenti nel SGI; (c) le esclusioni di perimetro SGI dichiarate dall'Alta Direzione; (d) il riallineamento al principio del SGI integrato; (e) i 4 ribaltamenti decisi dall'Alta Direzione tra il 30/04 e il 04/05/2026 (3 OSS HTA + 1 NC\_min Vigilanza MDR/IVDR riassorbite nel perimetro SGI con emissione di IDL035 e PRO105).

La gap-list completa è riportata nell'allegato xls "TD-SGI-RPT003\_00 – Allegato Gap-List Audit Q2 2026.xlsx".

## 2. Principi strutturali del SGI di Toscana Diagnostica

Quattro principi strutturali del SGI di TD inquadrano la lettura del presente Report:

Principio 1 – Politica unica integrata: TD-SGI-POL001 rev 01 è la sola Politica del SGI, estesa a tutte le norme di riferimento con sezioni dedicate. Nessuna POL2-POL8 separata per norma.

Principio 2 – Perimetro SGI definito: 9 elementi sono dichiarati fuori perimetro SGI per scelta strategica dell'Alta Direzione. Il perimetro è dinamico — al 04/05/2026 4 elementi sono stati riassorbiti nel perimetro con emissione documentale (3 driver HTA via IDL035 + Vigilanza MDR/IVDR via PRO105).

Principio 3 – Lingua corretta: tutti i documenti del SGI sono redatti in italiano formale con accenti completi e ortografia rigorosa.

Principio 4 – Numerazione progressiva con riutilizzo gap: prima di assegnare un nuovo codice, vengono valutati e prioritariamente utilizzati i 35 codici disponibili nei gap delle famiglie esistenti (mappa codici disponibili al 04/05/2026).

## 3. Sintesi executive Audit Q2 2026 (consolidata 04/05/2026)

Sono stati esaminati 452 documenti codificati distribuiti su 18 aree del SGI. Le risultanze totali dell'audit Q2 2026 sono 64, distribuite come segue:

- Aperte alla chiusura del consolidamento Q2: 10 (0 NC Maggiori, 0 NC Minori, 10 Osservazioni)
- Chiuse formalmente durante l'audit: 43 (grazie alle 49 azioni emissive 28/04–04/05 e al riconoscimento di documenti esistenti)
- Fuori perimetro SGI: 9
- Non applicabili: 2
- Aperte per priorità: P1 = 7, P2 = 2, P3 = 1

Il dato di rilievo strategico è ZERO NC MAGGIORI e ZERO NC MINORI residue (era 15 + 25 nella rev 00 originaria del 29/04). Il SGI è in stato di sostanziale conformità documentale al 04/05/2026.

### 3.1 Quadro numerico per area

| #  | Area                            | Doc | NC_maj | NC_min | OSS | Aperte | Chiuse | F.per. |
|----|---------------------------------|-----|--------|--------|-----|--------|--------|--------|
| 01 | Gestione del Sistema            | 15  | 0      | 0      | 0   | 0      | 4      | 0      |
| 02 | Anticorruzione e Whistleblowing | 7   | 0      | 0      | 4   | 4      | 0      | 0      |
| 03 | Parità di Genere                | 4   | 0      | 0      | 0   | 0      | 3      | 0      |
| 04 | Sostenibilità                   | 2   | 0      | 0      | 0   | 0      | 4      | 0      |
| 05 | Sicurezza                       | 11  | 0      | 0      | 1   | 1      | 3      | 0      |
| 06 | Tutela dell'Ambiente            | 6   | 0      | 0      | 0   | 0      | 2      | 0      |
| 07 | Rischio Clinico                 | 5   | 0      | 0      | 0   | 0      | 4      | 0      |
| 08 | Sistema Informativo             | 19  | 0      | 0      | 1   | 1      | 4      | 0      |
| 09 | Privacy                         | 11  | 0      | 0      | 0   | 0      | 2      | 1      |
| 10 | Audit                           | 4   | 0      | 0      | 0   | 0      | 3      | 0      |
| 11 | HTA                             | 14  | 0      | 0      | 0   | 0      | 3      | 0      |
| 12 | People                          | 29  | 0      | 0      | 0   | 0      | 2      | 1      |
| 13 | Finance                         | 5   | 0      | 0      | 0   | 0      | 2      | 2      |
| 14 | Operations                      | 15  | 0      | 0      | 1   | 1      | 1      | 0      |
| 15 | Customer Experience             | 8   | 0      | 0      | 0   | 0      | 3      | 0      |
| 16 | Business                        | 166 | 0      | 0      | 1   | 1      | 2      | 1      |
| 17 | Accettazione                    | 27  | 0      | 0      | 1   | 1      | 0      | 2      |
| 18 | Laboratorio di Analisi          | 66  | 0      | 0      | 1   | 1      | 1      | 2      |

## 4. Schede di audit per area – SWOT analysis Audit Q2 2026

Le sezioni 4.1-4.18 riportano per ciascuna area: norma di riferimento, sintesi documentale, SWOT analysis con punti di debolezza e rischi rilevati, elenco delle risultanze con stato dichiarato (APERTA / CHIUSA / FUORI PERIMETRO / NON APPLICABILE).

### 4.1 Area 01 – Gestione del Sistema

Norma primaria: ISO 9001:2015 §4-§10 (sistema integrato)

Norme secondarie: ISO 19011:2018 (audit), tutte le norme di riferimento del SGI come framework integrato

Documenti codificati: 15.

Area di governance del SGI: REG006 (Indice), MAN001 (Manuale), POL001, PRO007 (Audit), PRO008 (Riesame), PRO054 (Comunicazione), PLN001 (Piano obiettivi), 7 moduli di tracciatura (MOD039 Risk Register, MOD174-179 allegati comunicazione), RPT001 e RPT002 (Report Benchmark Q1+Q2 2026).

#### SWOT analysis (Audit Q2 2026):

| Quadrante                  | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                              |
|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza) | <ul style="list-style-type: none"> <li>Esistono Manuale (MAN001), Politica (POL001) e Piano obiettivi (PLN001) — i tre documenti cardine ISO 9001 §4-§5 sono presenti.</li> <li>Procedura formale di Riesame della Direzione (PRO008) e di audit interno (PRO007) emesse e attive.</li> <li>Indice REG006 coerentemente versionato (rev 16) con storico revisioni completo, autoreferenza R6, copertina aggiornata.</li> </ul> |

|                                    |    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|------------------------------------|----|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                    |    | <ul style="list-style-type: none"> <li>• Risk register MOD039 in vigore — base per ISO 9001 §6.1 risk-based thinking.</li> <li>• Procedura di comunicazione interna/esterna PRO054 con 6 moduli allegati (MOD174-179) — copre §7.4.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Weaknesses<br>(punti di debolezza) | di | <ul style="list-style-type: none"> <li>• POL001 unica - in coerenza con principio del SGI integrato - da estendere con sezioni dedicate per ciascuna norma (Information Security richiesta da ISO 27001 §A.5.1; Ambientale da ISO 14001 §5.2; SSL da ISO 45001 §5.2; Anti-corruzione da ISO 37001 §5.2; Privacy da ISO 27701 §5.2; People da ISO 30415 §5).</li> <li>• Risk Register MOD039 in formato modulo — manca evidenza di registro consolidato vivo con valutazioni quantitative aggiornate per i rischi ISO 27001/45001/14001.</li> <li>• Statement of Applicability ISO 27001 (richiesto §6.1.3) non risulta presente nell'indice come documento codificato — gap critico in ottica certificazione 27001.</li> <li>• Manca un documento dedicato alla "Comprensione del contesto" (ISO 9001 §4.1) e "Stakeholder" (§4.2): tipicamente è un'analisi PESTEL/SWOT iniziale + matrice stakeholder.</li> <li>• PLN001 Piano obiettivi: serve verifica di aggiornamento annuale (target/indicatori/responsabilità) — il documento è del 15/04/2026, da rivedere a fine 2026.</li> </ul> |
| Opportunities<br>(opportunità)     |    | <ul style="list-style-type: none"> <li>• Formalizzare il SoA ISO 27001 come REG (es. REG016) entro 30/06/2026 — rimuove il gap principale per la futura certificazione 27001.</li> <li>• Codificare un MOD di analisi del contesto e degli stakeholder annualmente aggiornato — soddisfa esplicitamente §4.1-§4.2 di ogni norma ISO HLS.</li> <li>• RPT002 (Report Benchmark Q2 2026) introduce roadmap pluriennale: trasformare le sue priorità P1 in obiettivi PLN001 con KPI espliciti.</li> <li>• Integrazione con la nuova ISO 9001:2026 (revisione attesa) — anticipare l'allineamento può ridurre il costo di re-certificazione.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Threats (rischi e minacce)         |    | <ul style="list-style-type: none"> <li>• Coesistenza di multi-norma (10+ standard) richiede mappatura cross-references puntuale: rischio di duplicazione/contraddizione fra documenti se manca un master matrix.</li> <li>• Riesame della Direzione (§9.3) deve essere documentato come verbale: in mancanza di evidenze di Riesami già svolti nel 2026, l'audit di certificazione lo segnalerà come NC maggiore.</li> <li>• Indice REG006 ha avuto 16 revisioni in poche settimane: rapidità lodevole ma il rischio di errori ortografici o di disallineamento codice-titolo è elevato — verifica puntuale necessaria pre-audit.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                                                  | Raccomandazione / Stato chiusura            |
|---|--------|-----|--------|------------------------------------------------------------------------------|---------------------------------------------|
| 1 | NC_maj | P1  | CHIUSA | Statement of Applicability ISO 27001 non codificato nell'indice              | CHIUSA - REG016 SoA emesso il 29/04/2026    |
| 2 | OSS    | P2  | CHIUSA | Manca di documento codificato per Analisi del Contesto e Stakeholder Mapping | CHIUSA - TD-SGI-MOD201 emesso il 30/04/2026 |

|   |     |    |        |                                                                                            |                                                                                            |
|---|-----|----|--------|--------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| 3 | OSS | P1 | CHIUSA | Verifica esistenza verbali Riesame della Direzione 2026                                    | CHIUSA - PRO002 'Rapporto di Riesame Iniziale SGI' presente in cartella 1 - costituisce il |
| 4 | OSS | P1 | CHIUSA | POL001 da estendere con sezioni dedicate per ciascuna norma (IS, Ambiente, SSL, Anticorruz | CHIUSA - POL001 rev 01 estesa con tutte le sezioni dedicate per ciascuna norma del SGI     |

## 4.2 Area 02 – Anticorruzione e Whistleblowing

Norma primaria: ISO 37001:2016, D.Lgs. 231/2001, D.Lgs. 24/2023 (Whistleblowing)

Norme secondarie: UNI ISO 37301:2021 (Compliance Management Systems), Direttiva (UE) 2019/1937

Documenti codificati: 7.

PRO003 (Whistleblowing), PRO004 (Flussi OdV), PRO005 (Omaggi), PRO006 (Due diligence soci), MOD002 (Due diligence dipendenti), MOD003 (Riesame Funzione Conformità), MOD160 (?). Modello 231 e Codice Etico in elaborazione presso Studio Maresca.

### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|---------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• Procedure complete sui processi cardine 37001: whistleblowing (PRO003), flussi informativi all'OdV (PRO004), gestione omaggi (PRO005), due diligence soci e partner (PRO006).</li> <li>• Esistono moduli operativi MOD002 (DD dipendenti) e MOD003 (riesame periodico Compliance Function) — coerenti con la struttura della Funzione di Conformità ex 37001.</li> <li>• PRO003 recepisce esplicitamente il D.Lgs. 24/2023, garantendo allineamento normativo aggiornato sul whistleblowing.</li> <li>• Iniziativa esterna (Studio Maresca) per l'adozione del Modello 231 — segnale di approccio strutturato al governance risk.</li> </ul>                                                                                                                                                             |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• Modello di Organizzazione, Gestione e Controllo ex D.Lgs. 231/2001 NON ancora codificato nell'indice — gap formale fino alla delibera di adozione attesa nelle prossime settimane.</li> <li>• Codice Etico aziendale non risulta come documento codificato nell'indice — è un prerequisito sostanziale del Modello 231 (art. 6 c. 3) e di ISO 37001 §5.2.</li> <li>• Catalogo dei reati 231 (mappatura processi sensibili → reati) non emerge come documento separato — tipicamente è un allegato al Modello 231.</li> <li>• Missing: Politica anticorruzione formalmente codificata come POL (richiesta da ISO 37001 §5.2) — può essere parte integrante di POL001 ma deve essere esplicita.</li> <li>• OdV: composizione e regolamento di funzionamento non risultano documenti codificati.</li> </ul> |
| Opportunities (opportunità)     | <ul style="list-style-type: none"> <li>• Adozione Modello 231 + Codice Etico delibera prossima settimana: cogliere l'occasione per emettere subito POL004 Politica Anticorruzione, REG017 Modello 231, REG018 Codice Etico.</li> <li>• Allineare la Funzione di Conformità 37001 con la Compliance Function 37301 — ottimizza il presidio compliance integrato.</li> <li>• Sinergia con whistleblowing AI Act art. 87 (riservatezza segnalazioni) e con whistleblowing NIS2 art. 25 sull'incident reporting interno.</li> <li>• Audit interno 37001 da pianificare nel PLN006 entro Q4 2026.</li> </ul>                                                                                                                                                                                                                                           |

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Threats (rischi e minacce) | <ul style="list-style-type: none"> <li>• Senza Modello 231 emesso, in caso di ipotetico illecito 231 TD non beneficia dell'esimente dell'art. 6 — esposizione al rischio di responsabilità amministrativa fino a 1,5 mln €.</li> <li>• Funzione di Conformità: art. 6 c. 1 lett. b) richiede autonomia ed indipendenza — verificare che la persona designata non abbia conflitti.</li> <li>• ANAC: D.Lgs. 24/2023 prevede sanzioni fino a 50.000 € per inadeguatezza canale whistleblowing — verifica del canale digitale interno fondamentale.</li> </ul> |
|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

#### Risultanze di audit:

| # | Tipo | Pri | Stato  | Descrizione                                                 | Raccomandazione / Stato chiusura                                                            |
|---|------|-----|--------|-------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| 1 | OSS  | P1  | APERTA | Modello 231 + Codice Etico in adozione (Studio Maresca)     | Codificare REG017/REG018 alla delibera CdA - presidiato esternamente                        |
| 2 | OSS  | P1  | APERTA | Composizione e Regolamento OdV in adozione (Studio Maresca) | Verifica codificazione di REG019 alla delibera CdA - presidiato esternamente                |
| 3 | OSS  | P1  | APERTA | Catalogo dei reati 231 e mappatura risk                     | Allegare al Modello 231 la matrice processi-reati con probabilità/impatto per ciascun reato |
| 4 | OSS  | P1  | APERTA | Verifica adeguatezza canale whistleblowing digitale         | Test funzionale del canale (anonimato, riservatezza, tracciabilità) prima di adozione form  |

### 4.3 Area 03 – Parità di Genere

Norma primaria: UNI PdR 125:2022 (Parità di Genere)

Norme secondarie: ISO 30415:2021 (Diversity & Inclusion)

Documenti codificati: 4.

DEX001 (Normativa di riferimento), PLN002 (Piano strategico), REG001 (Atto costituzione Comitato Guida), REG002 (Regolamento Comitato Guida).

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|---------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• Atto costitutivo (REG001) e Regolamento (REG002) del Comitato Guida per la Parità di Genere — soddisfa il requisito UNI PdR 125 §6.1 (governance).</li> <li>• Piano strategico PLN002 emesso — soddisfa §6.2.</li> <li>• Documento esterno DEX001 con normativa di riferimento — utile per training e audit (§6.6 PdR 125).</li> </ul>                                                                                                                                                                                                                                                                                                                                                            |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• Mancano documenti operativi previsti da UNI PdR 125 §6.3-§6.7: KPI specifici (es. gender pay gap), procedure di monitoraggio, procedure di gestione molestie/violenza di genere, processo di selezione gender-neutral.</li> <li>• Indicatori di parità (sui 6 ambiti UNI PdR 125: cultura/strategia, governance, HR, opportunità, equità retributiva, parental support, work-life balance) non risultano come MOD codificati con valori/target/baseline.</li> <li>• ISO 30415 (D&amp;I esteso oltre la sola parità di genere) non ha documenti propri — copertura ridotta a una sola dimensione (gender), trascurando dimensioni come età, etnia, disabilità, orientamento, religione.</li> </ul> |

|                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Opportunities (opportunità) | <ul style="list-style-type: none"> <li>• Certificazione UNI PdR 125 come passo successivo logico (la struttura documentale è già impostata): emissione MOD/PRO operative entro Q3 2026 per audit certificativo Q4 2026.</li> <li>• Estensione documentale ISO 30415 D&amp;I — sinergia con ESG Reporting (Area 04) e con CSRD (S1 own workforce).</li> <li>• Adesione a benchmark esterni (es. Bloomberg Gender-Equality Index) come driver di competitività e attrazione talenti.</li> </ul> |
| Threats (rischi e minacce)  | <ul style="list-style-type: none"> <li>• Senza KPI quantitativi tracciati, l'audit certificazione UNI PdR 125 esita in NC: la PdR richiede esplicitamente misurazione del gender pay gap per inquadramento.</li> <li>• PNRR/L. 162/2021: incentivi per certificate di parità sono temporanei — finestra di opportunità da non perdere.</li> </ul>                                                                                                                                             |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                                      | Raccomandazione / Stato chiusura                                                      |
|---|--------|-----|--------|------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| 1 | NC_maj | P1  | CHIUSA | Indicatori UNI PdR 125 §6.3-§6.7 non codificati come MOD         | CHIUSA - TD-SGI-MOD202 emesso il 30/04/2026 con i 33 KPI sui 6 ambiti UNI PdR 125     |
| 2 | NC_min | P1  | CHIUSA | Mancanza di procedura per gestione molestie e violenza di genere | CHIUSA - TD-SGI-PRO087 emesso il 30/04/2026                                           |
| 3 | OSS    | P2  | CHIUSA | ISO 30415 D&I non implementata                                   | CHIUSA - PLN002 rev 01 estende a visione D&I integrale (10 dimensioni ISO 30415:2021) |

## 4.4 Area 04 – Sostenibilità

Norma primaria: CSRD/ESRS (Direttiva (UE) 2022/2464), GRI Standards 2021, PAS 24000:2022

Norme secondarie: ISO 14001 (collegata Area 06), ISO 26000:2010, SDG ONU, SBTi

Documenti codificati: 2.

IDL001 (buone pratiche sostenibilità), PLN003 (Report sostenibilità GRI). Solo 2 documenti — area documentale minima.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|---------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• Esiste un Report di Sostenibilità (PLN003) impostato su standard GRI — copertura disclosure ESG di base.</li> <li>• IDL001 fornisce orientamento operativo sulle buone pratiche.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• Solo 2 documenti per un'area che, in azienda sanitaria privata, dovrebbe ospitare diverse decine di documenti — gap documentale significativo.</li> <li>• Manca politica di sostenibilità formalizzata (POL).</li> <li>• Manca matrice di materialità (richiesta da CSRD/ESRS 1) come MOD.</li> <li>• Mancano i 4 documenti operativi PAS 24000:2022 (Sustainability of organizations): policy, piano d'azione, KPI, comunicazione esterna.</li> <li>• Carbon footprint aziendale (richiesto da CSRD ESRS E1) non risulta come MOD/RPT codificato.</li> <li>• Stakeholder engagement plan ESG non documentato.</li> <li>• Manca riferimento ai 17 SDG ONU come framework di obiettivi.</li> </ul> |
| Opportunities                   | <ul style="list-style-type: none"> <li>• PAS 24000:2022 è già nel set di norme dichiarate del SGI — emettere il</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|----------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| (opportunità)              | <p>pacchetto documentale completo è un quick win di alta visibilità.</p> <ul style="list-style-type: none"> <li>• Sinergia con ISO 14001 (Area 06) e con UNI PdR 125 (Area 03): lo Statement of Sustainability può unificare le tre dimensioni in un Report ESG integrato.</li> <li>• CSRD obbligatoria per Toscana Diagnostica come PMI quotata (se quotata) o come grande società per dimensione/fatturato — verificare soglie applicabili. Comunque trend di reporting volontario può fornire vantaggio competitivo nei tender SSN.</li> <li>• GRI Standards 2021 + ERSR-set 1 disponibili: usabili come scheletro completo del Report Sostenibilità.</li> </ul> |
| Threats (rischi e minacce) | <ul style="list-style-type: none"> <li>• Greenwashing risk: pubblicare un Report ESG senza basi quantitative robuste espone a contestazioni di Autorità (AGCM, CONSOB) e di stakeholder.</li> <li>• CSRD si applica gradualmente fino al 2028 — verificare puntualmente l'applicabilità per TD.</li> <li>• ESG-related ESG procurement: bandi sanitari pubblici iniziano a richiedere disclosure ESG — assenza di certificazione/report formale può escludere TD da tender futuri.</li> </ul>                                                                                                                                                                       |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                     | Raccomandazione / Stato chiusura                                                            |
|---|--------|-----|--------|-------------------------------------------------|---------------------------------------------------------------------------------------------|
| 1 | NC_maj | P2  | CHIUSA | Pacchetto documentale PAS 24000:2022 incompleto | CHIUSA - POL001 rev 01 §2.4 ESG + PLN011 (SDG + CSRD) + MOD204 (KPI ESG) + MOD205 (Materia) |
| 2 | NC_min | P2  | CHIUSA | Matrice di materialità ESG non documentata      | CHIUSA - MOD205 Matrice di Materialità Doppia (impact + financial)                          |
| 3 | OSS    | P3  | CHIUSA | Carbon footprint aziendale non quantificata     | CHIUSA - MOD223 Inventario Emissioni GHG Scope 1+2+3                                        |
| 4 | OSS    | P2  | CHIUSA | Verifica applicabilità CSRD a TD                | CHIUSA - PLN011 Parte 2 analisi soglie post-Omnibus: TD non obbligata, adesione VSME possi  |

## 4.5 Area 05 – Sicurezza

Norma primaria: ISO 45001:2018, D.Lgs. 81/2008

Norme secondarie: ISO 14001 (collegata salute lavoratori-ambiente), Reg. UE 2016/425 DPI

Documenti codificati: 11.

PRO009-PRO014 (6 procedure), MOD005 (radioprotezione), MOD006 (classificazione lavoratori), MOD007 (DPI), IDL003 (igiene mani), IDL004 (?). 11 doc su area Sicurezza in laboratorio + studio.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                  | Elementi rilevati                                                                                                                                                                                                                                                                                                                         |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza) | <ul style="list-style-type: none"> <li>• Procedure operative complete su radioprotezione (MOD005), sorveglianza sanitaria (MOD006), DPI (MOD007).</li> <li>• IDL003 igiene mani — coerente con linee guida WHO/Ministero per healthcare workers.</li> <li>• Set procedurale (PRO009-PRO014) copre il ciclo classico ISO 45001:</li> </ul> |

**Toscana Diagnostica S.r.l.**

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.  
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

|                                    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                    | hazard identification, risk assessment, controlli, sorveglianza.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Weaknesses<br>(punti di debolezza) | <ul style="list-style-type: none"> <li>• Documento di Valutazione dei Rischi (DVR ex art. 28 D.Lgs. 81/2008) non risulta codificato come REG/MAN — potrebbe essere documento extra-SGI ma il riferimento incrociato è essenziale.</li> <li>• Manca specifica documentazione sul Rischio Biologico (Titolo X D.Lgs. 81/2008) — particolarmente rilevante per laboratori di analisi cliniche.</li> <li>• Manca documento sul Rischio Chimico (Titolo IX) — laboratori usano reagenti molteplici.</li> <li>• Politica di Salute e Sicurezza (POL ISO 45001 §5.2) non esplicitata.</li> <li>• Piano di Emergenza (D.M. 02/09/2021) non risulta codificato come PLN.</li> <li>• Procedura di gestione near miss e statistiche infortuni: non chiaro se MOD esiste.</li> </ul> |
| Opportunities<br>(opportunità)     | <ul style="list-style-type: none"> <li>• Certificazione ISO 45001 fattibile entro 2026 con ridotta integrazione documentale — il pacchetto è ~70% pronto.</li> <li>• Sinergia con Area 18 Laboratorio (rischio biologico-chimico): gli stessi documenti coprono ISO 45001 + ISO 15189 §6.4.</li> <li>• Allineamento con ISO 7101:2023 (rischio operatori sanitari §6.3) — già strutturato in PRO028 prevenzione violenza.</li> </ul>                                                                                                                                                                                                                                                                                                                                     |
| Threats (rischi e minacce)         | <ul style="list-style-type: none"> <li>• DVR mancante o non aggiornato è la prima causa di NC maggiore in audit ISO 45001.</li> <li>• Rischio sanzionatorio art. 55 D.Lgs. 81/2008: fino a 7.500 € per RSPP non identificato, fino a 6.400 € per DVR carente.</li> <li>• Specificità sanitaria: in audit l'omessa valutazione rischio biologico/chimico è considerata grave indipendentemente dalla certificazione.</li> </ul>                                                                                                                                                                                                                                                                                                                                           |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                                                          | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|--------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | OSS    | P1  | CHIUSA | DVR ex art. 28 D.Lgs. 81/2008 in arrivo (presidiato dal RSPP - in revisione esterna) | CHIUSA - TD-SGI-REG020 'DVR Laboratorio Sesto Fiorentino' emesso il 04/05/2026 con copertu |
| 2 | NC_maj | P1  | CHIUSA | Documenti Rischio Biologico e Chimico non codificati come PRO/REG                    | CHIUSA - TD-SGI-PRO089 (Biologico) + TD-SGI-PRO110 (Chimico) emessi il 30/04/2026          |
| 3 | OSS    | P1  | APERTA | Piano di Emergenza ex D.M. 02/09/2021 in arrivo (presidiato dal RSPP)                | Codificare TD-SGI-PLN012 al completamento - già presidiato                                 |
| 4 | OSS    | P2  | CHIUSA | MOD per registrazione infortuni e near miss                                          | CHIUSA - MOD031 'Modulo segnalazione infortuni sul lavoro' esistente in Area 12            |

## 4.6 Area 06 – Tutela dell'Ambiente

Norma primaria: ISO 14001:2015

Norme secondarie: D.Lgs. 152/2006 (T.U. Ambiente), Reg. UE 2017/745 (rifiuti sanitari pericolosi), CSRD ESRS E1-E5

Documenti codificati: 6.

PRO015 (?), PRO020 (?), PRO021 (?), PLN004 (Risk assessment ambientale), IDL002 (?), IDL025 (?). 6 doc su area Ambiente.

**Toscana Diagnostica S.r.l.**

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.  
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
|---------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• Piano di risk assessment ambientale PLN004 emesso — coerente con ISO 14001 §6.1.</li> <li>• Set procedurale (PRO015/020/021) copre alcuni aspetti operativi.</li> <li>• Presenza di IDL025 (rifiuti sanitari pericolosi presumibilmente) — area critica per laboratorio.</li> </ul>                                                                                                                                                                                                                                                                                                  |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• Politica Ambientale (ISO 14001 §5.2) non risulta come POL codificata.</li> <li>• Aspetti ambientali (§6.1.2) — registro mancante.</li> <li>• Obblighi di compliance ambientale (§6.1.3) — non evidente come MOD strutturato (autorizzazioni, scarichi, emissioni, rifiuti).</li> <li>• Programmi ambientali (§6.2) — lo STAR del set ISO 14001 potrebbe essere coperto da PLN004 ma non chiaro.</li> <li>• Comunicazione ambientale interna ed esterna (§7.4) non documentata.</li> <li>• Audit interno e Riesame dedicati ambiente (§9.2-§9.3) non esplicitati come PRO.</li> </ul> |
| Opportunities (opportunità)     | <ul style="list-style-type: none"> <li>• Set documentale ridotto (6 doc) ma struttura agile da espandere — certificazione ISO 14001 fattibile in 2026 con investimento documentale moderato (8-10 nuovi documenti).</li> <li>• Sinergia con CSRD ESRS E1 (Climate), E5 (Resource use) — riuso documentazione 14001 per disclosure ESG.</li> <li>• Diagnostica per immagini (radiologia): radiazioni ionizzanti hanno aspetti ambientali rilevanti — documentare li copre sia 14001 che D.Lgs. 101/2020 (radioprotezione).</li> </ul>                                                                                          |
| Threats (rischi e minacce)      | <ul style="list-style-type: none"> <li>• Sanzioni ambientali per cattiva gestione rifiuti sanitari: D.Lgs. 152/2006 prevede fino a 26.000 € + responsabilità 231 (art. 25-undecies).</li> <li>• Costi smaltimento rifiuti sanitari in crescita: senza monitoraggio puntuale TD può accumulare costi non gestiti.</li> <li>• Reg. UE 2024/1735 (Plastic Pollution) e Reg. UE 2024/3110 (Packaging) — nuovi obblighi che impattano sui consumabili di laboratorio.</li> </ul>                                                                                                                                                   |

### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                                         | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|---------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | NC_min | P1  | CHIUSA | Registro Aspetti Ambientali e Compliance Obligations non codificato | CHIUSA - TD-SGI-REG023 Registro Aspetti Ambientali e Compliance Obligations emesso il 30/0 |
| 2 | OSS    | P1  | CHIUSA | Procedura specifica gestione rifiuti sanitari pericolosi            | CHIUSA - TD-SGI-PRO091 Gestione Rifiuti Sanitari Pericolosi emesso il 30/04/2026           |
| 3 | OSS    | P3  | N/A    | Carbon footprint laboratorio (Scope 1+2+3)                          | NON APPLICABILE - TD non ha sorgenti significative di emissioni dirette in atmosfera; Scop |

## 4.7 Area 07 – Rischio Clinico

Norma primaria: ISO 7101:2023 (Healthcare Quality and Safety Management), DM 11/01/2024

**Toscana Diagnostica S.r.l.**

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.  
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

Norme secondarie: ISO 9001 §6.1, ISO 22367 (laboratory risk), Raccomandazioni Ministero Salute

Documenti codificati: 5.

DEX002 (Normativa rischio clinico), MOD024 (?), MOD040 (?), PLN005 (Piano obiettivi), PRO025 (?). 5 doc — area documentale agile ma da rafforzare.

### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|---------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• PLN005 Piano Obiettivi rischio clinico — coerente con ISO 7101 §6.2.</li> <li>• DEX002 normativa di riferimento — utile per training Patient Safety.</li> <li>• Esistenza MOD operativi suggerisce alcune attività di tracciatura eventi avversi.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• ISO 7101:2023 è recente (luglio 2023) e richiede integrazione esplicita di alcuni elementi: cultura sicurezza paziente (§5.1.4), human factors engineering (§7.7), patient &amp; family engagement (§7.4).</li> <li>• Tassonomia eventi avversi ICPS WHO non risulta codificata come MOD.</li> <li>• Procedura SEA (Significant Event Analysis) e RCA per eventi avversi clinici non chiaramente codificata.</li> <li>• Patient Safety Plan annuale: PLN005 può essere ridotto rispetto ai contenuti minimi DM 11/01/2024.</li> <li>• Cruscotto indicatori sicurezza paziente (mortalità, infezioni, errori, near miss) non codificato come MOD/RPT.</li> <li>• Procedura di comunicazione eventi avversi al paziente/famiglia (open disclosure §7.4) non chiara.</li> </ul> |
| Opportunities (opportunità)     | <ul style="list-style-type: none"> <li>• TD ha dichiarato ISO 7101 come norma di riferimento: certificazione possibile entro 2027 con investimento documentale strutturato — pochi competitor IT certificati ISO 7101 = vantaggio competitivo.</li> <li>• Sinergia con Area 18 Laboratorio (ISO 22367 risk management laboratorio) e Area 17 Accettazione (errori pre-analitici).</li> <li>• Sinergia con AI Governance (Area 08): rischi clinici da AI in radiologia/anatomia patologica — copertura PRO085.</li> </ul>                                                                                                                                                                                                                                                                                              |
| Threats (rischi e minacce)      | <ul style="list-style-type: none"> <li>• DM 11/01/2024 (Sistema Nazionale per la Sicurezza dei Pazienti) impone obblighi di reporting al Ministero — verificare adempimento.</li> <li>• Class action collettive per malasanità in crescita — patient safety system robusto è la prima difesa.</li> <li>• Direttiva (UE) 2024/1346 (Patients' Rights cross-border) impone trasparenza qualità: essere in audit-ready è prerequisite.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                        |

### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                        | Raccomandazione / Stato chiusura                                     |
|---|--------|-----|--------|----------------------------------------------------|----------------------------------------------------------------------|
| 1 | NC_maj | P1  | CHIUSA | Tassonomia eventi avversi ICPS WHO non documentata | CHIUSA - TD-SGI-MOD209 emesso il 30/04/2026                          |
| 2 | NC_maj | P1  | CHIUSA | Procedura SEA/RCA per Patient Safety               | CHIUSA - TD-SGI-PRO092 emesso il 30/04/2026                          |
| 3 | NC_min | P1  | CHIUSA | Cruscotto indicatori Patient Safety                | CHIUSA - TD-SGI-MOD210 emesso il 30/04/2026                          |
| 4 | OSS    | P2  | CHIUSA | Open Disclosure procedura                          | CHIUSA - PRO093 Comunicazione Open Disclosure (ISO 7101 §7.4 + Legge |

24/2017)

## 4.8 Area 08 – Sistema Informativo

Norma primaria: ISO/IEC 27001:2022, NIS2 (D.Lgs. 138/2024), AI Act (Reg. UE 2024/1689)

Norme secondarie: ISO/IEC 27701 (PIMS), ISO/IEC 22301 (BCMS), EHDS (Reg. UE 2025/327), GDPR (cross-area), ISO/IEC 42001:2023 (AI MS)

Documenti codificati: 19.

Area appena rafforzata: PRO070 (NIS2), PRO085 (AI Gov), PRO016-019 (procedure base), MOD011/197/198/199/200/181/182/183/184 (9 moduli), REG003 (?), IDL026/034 (2 IDL), PLN009 (Piano MTOM). 19 doc — area più densa documentalmente del SGI dopo Lab e Business.

### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|---------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• Cantiere NIS2 e AI Governance entrambi documentalmente chiusi: PRO070+MOD181-184+IDL026+MOD200+PLN009 (NIS2), PRO085+MOD197-199+IDL034 (AI).</li> <li>• Catena di risposta a 5 fasi NIS2 documentata con tempistiche T0+24h/72h/30gg, multi-autorità.</li> <li>• Registro AI MOD197 con classificazione del rischio AI Act in 4 fasce e 10 sistemi candidati pre-compilati.</li> <li>• PLN009 Piano MTOM strutturato su 10 aree mappate su ISO 27001 Annex A — tracciamento puntuale verso scadenza 1/10/2026.</li> <li>• Designazione formale PdC NIS (MOD200): AD/Francesco Epifani con sostituto RSGL.</li> </ul>                                                                                                                                                                                                                                          |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• SoA ISO 27001 non codificato (cfr. Area 01 — gap principale).</li> <li>• Politica Sicurezza Informazioni esplicita (POL ISO 27001 §A.5.1) non emessa.</li> <li>• Politiche specifiche ISO 27001 §A: politica accesso (A.5.15), classificazione informazioni (A.5.12), crittografia (A.8.24), backup (A.8.13), gestione incidenti (A.5.24) — alcune coperte da procedure ma non tutte come politiche dedicate.</li> <li>• Risk assessment ISO 27005 (registro rischi IS) non codificato come MOD specifico.</li> <li>• Privacy Impact Assessment (DPIA) procedura — sebbene riferita in PRO085, non risulta come PRO codificata in Area 09.</li> <li>• Continuità operativa ICT (BCP+DRP) non emersa come PLN/PRO codificato — gap critico anche per NIS2 (Area MTOM 3).</li> <li>• Vulnerability Management: procedura formalmente non codificata.</li> </ul> |
| Opportunities (opportunità)     | <ul style="list-style-type: none"> <li>• Certificazione ISO 27001 entro 2027 fattibile partendo dall'apparato attuale — investimento documentale ~15 nuovi documenti + SoA.</li> <li>• ISO 27701 (PIMS) come estensione naturale dopo 27001 + GDPR.</li> <li>• ISO 42001:2023 (AI Management System) — PRO085 è già allineato; certificazione possibile come differenziatore competitivo.</li> <li>• EHDS (Reg. UE 2025/327): TD può posizionarsi come provider 'data altruista' nel settore sanitario — vantaggio competitivo Q4 2027.</li> </ul>                                                                                                                                                                                                                                                                                                                                                     |
| Threats (rischi e minacce)      | <ul style="list-style-type: none"> <li>• Scadenza NIS2 1/10/2026 vincolante: cruscotto MTOM al 41,5% al 29/04/2026 — rischio non rispetto scadenza con sanzioni ACN fino a 10 mln € o 2% fatturato.</li> <li>• Scadenza AI Act 2/8/2026 (parte high-risk): sistemi LIS/RIS/PACS con AI</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |

possono ricadere in classificazione, sanzioni fino a 35 mln € o 7% fatturato.  
• Ransomware: settore sanitario è target #1 nel 2025 (ENISA Threat Landscape) — esposizione operativa elevata.

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                                                               | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|-------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | NC_maj | P1  | CHIUSA | SoA ISO 27001 non emesso                                                                  | CHIUSA - TD-SGI-REG016 SoA ISO 27001 emesso il 29/04/2026                                  |
| 2 | NC_maj | P1  | CHIUSA | BCP+DRP formali non codificati                                                            | CHIUSA - TD-SGI-PLN013 BCP + TD-SGI-PLN014 DRP + TD-SGI-MOD221 Verbale Test emessi il 30/0 |
| 3 | OSS    | P1  | CHIUSA | Politiche specifiche ISO 27001 Annex A coperte da PRO109 IS Policy operativa (in coerenza | CHIUSA - TD-SGI-PRO109 Information Security Policy operativa declina i controlli A.5.1, A. |
| 4 | NC_min | P1  | CHIUSA | Vulnerability Management procedura                                                        | CHIUSA - TD-SGI-PRO094 Vulnerability Management emesso il 30/04/2026                       |
| 5 | OSS    | P1  | APERTA | Piano di Adeguamento MTOM PLN009 al 41,5%                                                 | Cruscotto mensile RSGI+IT Manager + escalation CdA per scadenza 1/10/2026                  |

## 4.9 Area 09 – Privacy

Norma primaria: Reg. UE 2016/679 (GDPR), D.Lgs. 196/2003 (Codice Privacy)

Norme secondarie: ISO 27701:2019 (PIMS), Linee Guida EDPB/Garante

Documenti codificati: 11.

PRO030-037 (8 procedure), MOD028 (?), MOD029 (?), REG004 (Registro trattamenti?). 11 doc su Privacy.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|---------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>Set procedurale ricco (8 PRO) — copertura ampia degli obblighi GDPR.</li> <li>MOD028+029 e REG004 suggeriscono presenza di Registro Trattamenti — adempimento art. 30 GDPR.</li> <li>Cross-area con Area 08 (incidenti — data breach) e Area 17 (consensi paziente).</li> </ul>                                                                                                                                                                                                                                                                                                                                                                         |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>Politica Privacy formalmente codificata come POL non chiara (potrebbe essere parte di PRO030 ma deve essere POL).</li> <li>Designazione DPO formale come MOD non emerge — verifica su esistenza.</li> <li>Modello accountability GDPR (registro decisioni privacy by design, registro DPIA, registro trasferimenti extra-UE) — copertura non evidente.</li> <li>Processo cookie/tracking sui canali digitali (sito web, portale paziente) — PRO dedicata non chiara.</li> <li>Nomine responsabili esterni ex art. 28 GDPR (DPA): probabilmente sottoscritte ma non codificate come MOD generico.</li> <li>ISO 27701 PIMS — non implementata.</li> </ul> |

|                             |                                                                                                                                                                                                                                                                                                                                                                                                                         |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Opportunities (opportunità) | <ul style="list-style-type: none"> <li>• Certificazione ISO 27701 dopo ISO 27001 — sinergia massima e vantaggio competitivo per provider sanitari (rare in Italia).</li> <li>• Re-uso del Registro Trattamenti GDPR per CSRD ESRS S1/S4 (data subjects).</li> <li>• EHDS Reg. UE 2025/327 — 'Data altruism' opportunità di posizionamento per laboratori di analisi.</li> </ul>                                         |
| Threats (rischi e minacce)  | <ul style="list-style-type: none"> <li>• Sanzioni GDPR fino a 4% fatturato per violazione sostanziale — settore sanitario monitorato strettamente dal Garante.</li> <li>• Aumento data breach sanitari: secondo IBM 2025 cost-of-a-data-breach, sanità è settore con costo medio più alto (~10 mln \$/breach).</li> <li>• Garante Privacy ha intensificato controlli su laboratori di analisi nel 2024-2025.</li> </ul> |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                                        | Raccomandazione / Stato chiusura                                       |
|---|--------|-----|--------|--------------------------------------------------------------------|------------------------------------------------------------------------|
| 1 | NC_min | P1  | CHIUSA | Atto designazione DPO non chiaramente codificato                   | CHIUSA - MOD211 Designazione formale DPO emesso il 30/04/2026          |
| 2 | OSS    | P2  | CHIUSA | Registri DPIA, trasferimenti extra-UE, decisioni privacy by design | CHIUSA - MOD212 Registro DPIA + MOD213 Registro Trasferimenti Extra-UE |
| 3 | OSS    | P3  | F.PER. | ISO 27701 PIMS roadmap                                             | FUORI PERIMETRO SGI - osservazione fuori scope per scelta strategica   |

### 4.10 Area 10 – Audit

Norma primaria: ISO 19011:2018, ISO 9001:2015 §9.2

Norme secondarie: ISO 17021:2015 (per Enti certificatori), ISO 27007 (audit ISMS)

Documenti codificati: 4.

PRO007 (Audit interno), PLN006 (Piano annuale audit), MOD026 (?), MOD027 (?). Area governance audit minimal ma essenziale.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|---------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• PRO007 esistente per audit interno — soddisfa ISO 9001 §9.2.</li> <li>• PLN006 Piano annuale audit emesso — soddisfa §9.2.2.</li> <li>• Moduli operativi MOD026/027 presumibilmente per checklist e verbali audit.</li> </ul>                                                                                                                                                                                                                                                                                                                               |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• PLN006 deve essere annualmente aggiornato e coprire TUTTE le norme: 9001+45001+14001+27001+37001+7101+...; verifica che il calendario audit copra ogni norma certificate/in certificazione.</li> <li>• Manca evidenza di Reports di Audit interni 2026 svolti — verbali audit interni come MOD/RPT codificati non chiari.</li> <li>• Qualifica auditor interni (competenza ex ISO 19011 §7) — manca registro qualifiche.</li> <li>• Audit dei fornitori critici (cfr. Area 14 e Area 18 e MOD182 NIS2) — procedura formale specifica non chiara.</li> </ul> |
| Opportunities (opportunità)     | <ul style="list-style-type: none"> <li>• Coordinamento audit multi-norma: una sola sessione di audit annuale può coprire tutte le 10+ norme con risparmio operativo significativo.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                        |

|                            |                                                                                                                                                                                                                                                                                           |
|----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                            | <ul style="list-style-type: none"> <li>• Adozione di software di audit management (es. AuditBoard, Onspring) — riduce costo e migliora tracciabilità.</li> </ul>                                                                                                                          |
| Threats (rischi e minacce) | <ul style="list-style-type: none"> <li>• Senza audit interni documentati 2026, l'audit di certificazione può rilevare NC maggiore su §9.2.</li> <li>• Indipendenza auditor: ISO 9001 §9.2.2 c) richiede che l'auditor non audit propri processi — verifica della segregazione.</li> </ul> |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                   | Raccomandazione / Stato chiusura                                                          |
|---|--------|-----|--------|-----------------------------------------------|-------------------------------------------------------------------------------------------|
| 1 | NC_maj | P1  | CHIUSA | Reports di Audit interno 2026 non documentati | CHIUSA - MOD214 Verbale Audit Documentale SGI Q2 2026 (secondo audit programmato Q4 2026) |
| 2 | NC_min | P2  | CHIUSA | Registro qualifiche auditor interni           | CHIUSA - MOD215 Registro Qualifiche Auditor Interni                                       |
| 3 | OSS    | P2  | CHIUSA | Procedura audit fornitori critici             | CHIUSA - PRO034 rev 01 con concetto Fornitore Critico + audit periodicità                 |

### 4.11 Area 11 – HTA

Norma primaria: ISO 7101 Allegato HTA, Reg. UE 2021/2282 (HTA Regulation)

Norme secondarie: AIFA, EUnetHTA, MDR (Reg. UE 2017/745), IVDR (Reg. UE 2017/746)

Documenti codificati: 14.

PRO022 (?), PRO023 (?), PRO024 (?), 11 moduli MOD030-038+MOD046+047 (presumibilmente) — area HTA/Health Technology Assessment per valutazioni adozione tecnologie sanitarie. 14 doc.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|---------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• Set documentale numericamente robusto (14 doc) — segno di processo strutturato.</li> <li>• 3 procedure + 11 moduli — granularità operativa elevata.</li> <li>• Area distintiva di TD: pochi competitor IT hanno un processo HTA codificato in laboratorio diagnostica.</li> </ul>                                                                                                                                                                                                                                                           |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• Senza accesso al contenuto puntuale dei moduli, non si può verificare aderenza alla nuova HTA Regulation UE entrata in vigore in piena applicazione 2025-2030.</li> <li>• ISO 7101 Allegato HTA prevede componenti specifiche (technology scanning, evidence synthesis, economic evaluation, ethical assessment): copertura puntuale da verificare.</li> <li>• Sinergia con AI Governance (Area 08): nuove tecnologie AI in radiologia/anatomia patologica devono passare per l'HTA — collegamento PRO085 ↔ Area 11 da chiarire.</li> </ul> |
| Opportunities (opportunità)     | <ul style="list-style-type: none"> <li>• Posizionamento di TD come HTA leader fra i laboratori privati italiani — vantaggio competitivo nei tender SSN per nuove tecnologie diagnostiche.</li> <li>• Reg. UE 2021/2282 entra in piena applicazione 2025-2030: documentare puntualmente i Joint Clinical Assessments (JCA) può aprire opportunità di partecipazione a trial multicentrici.</li> <li>• Sinergia con IVDR: dispositivi diagnostici nuovi richiedono HTA per</li> </ul>                                                                                                  |

|                            |                                                                                                                                                                                                                                                                                   |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Threats (rischi e minacce) | inclusione in repertorio TD.<br>• HTA Regulation UE: gli stati membri devono recepire JCA — TD deve garantire allineamento dei propri processi a partire dal 2026.<br>• Senza chiarezza sui processi HTA, rischio di adottare tecnologie non costo-efficaci o non evidence-based. |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

#### Risultanze di audit:

| # | Tipo | Pri | Stato  | Descrizione                             | Raccomandazione / Stato chiusura                                                          |
|---|------|-----|--------|-----------------------------------------|-------------------------------------------------------------------------------------------|
| 1 | OSS  | P2  | CHIUSA | Verifica aderenza ISO 7101 Allegato HTA | CHIUSA - TD-SGI-IDL035 'Verifica aderenza HTA - ISO 7101 Allegato A.4 + Reg. UE 2021/2282 |
| 2 | OSS  | P2  | CHIUSA | Allineamento HTA Reg. UE 2021/2282      | CHIUSA - TD-SGI-IDL035 'Verifica aderenza HTA - ISO 7101 Allegato A.4 + Reg. UE 2021/2282 |
| 3 | OSS  | P2  | CHIUSA | Cross-reference Governance HTA-AI       | CHIUSA - TD-SGI-IDL035 'Verifica aderenza HTA - ISO 7101 Allegato A.4 + Reg. UE 2021/2282 |

## 4.12 Area 12 – People

Norma primaria: ISO 30415:2021, UNI PdR 125:2022, PAS 24000:2022, SA8000:2026

Norme secondarie: ISO 9001 §7.1.2 (people), CCNL Sanità Privata, GDPR art. 88 (lavoro)

Documenti codificati: 29.

PRO038-044 (7 procedure), PLN007 (Piano formativo), 16 moduli MOD071-087 (anagrafica HR, contratti, dati bancari, diritti lavoratori), 2 REG (?), 3 IDL. Area HR ricca documentalmente: 29 doc.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|---------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>Set procedurale completo per ciclo HR: 7 PRO + 16 MOD operativi.</li> <li>PLN007 piano formativo — soddisfa ISO 9001 §7.2 e UNI PdR 125 §6.6.</li> <li>Recente rev di PRO045 Inserimento neoassunti, PRO046 Valutazione performance, PRO049 (?) e MOD053 — segno di manutenzione attiva.</li> <li>Modulo deroga clausola esclusività (MOD079) — segno di attenzione a diritti lavoratori.</li> </ul>                                                                                                                                                                                                    |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>Politica HR / People Strategy formalmente non codificata come POL.</li> <li>Job Description e Mansionari come MOD/REG non emergono — fondamentale per ISO 9001 §7.1.2 (responsabilità) e per audit GDPR (segregazione duties).</li> <li>Procedura di gestione degli stress lavoro-correlato (D.Lgs. 81/2008 art. 28) — non chiaro se codificata.</li> <li>Performance Management: PRO046 esiste ma framework KPI individuale e collettivo non chiaro come MOD codificato.</li> <li>Cruscotto KPI HR (turnover, assenteismo, formazione, soddisfazione, gender pay) — da verificare presenza.</li> </ul> |
| Opportunities (opportunità)     | <ul style="list-style-type: none"> <li>Certificazione ISO 30415 D&amp;I + UNI PdR 125 + SA8000 in pacchetto unico People Sustainability — posizionamento differenziante nel settore.</li> <li>PAS 24000:2022 — già nel set TD: investimento documentale modesto su Area 12 chiude la copertura.</li> <li>Software di HRM (Workday, Hibob, BambooHR) — possibile</li> </ul>                                                                                                                                                                                                                                                                     |

|                            |                                                                                                                                                                                                                                                                                                                                                                                                                  |
|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                            | efficientamento e migliore audit-readiness.                                                                                                                                                                                                                                                                                                                                                                      |
| Threats (rischi e minacce) | <ul style="list-style-type: none"> <li>• Turnover settore sanitario ai massimi storici (~25%/anno per infermieri) — TD esposta a perdita di competenze critiche.</li> <li>• Mancato adeguamento a Direttiva (UE) 2023/970 (Pay Transparency) entro giugno 2026 — sanzioni amministrative.</li> <li>• Carenza di personale tecnico di laboratorio in Toscana — competizione su retribuzione e welfare.</li> </ul> |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                             | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|---------------------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | NC_maj | P1  | F.PER. | Job Description e Mansionari non codificati             | FUORI PERIMETRO SGI - elemento non rilevante per il SGI per scelta strategica - presidio o |
| 2 | OSS    | P1  | N/A    | Procedura stress lavoro-correlato esistente come PRO010 | CHIUSA per NON APPLICABILITA - PRO010 già nell'indice copre il requisito                   |
| 3 | OSS    | P2  | CHIUSA | Cruscotto KPI HR                                        | CHIUSA - MOD216 Cruscotto KPI HR con 40 KPI                                                |
| 4 | OSS    | P1  | CHIUSA | Pay Transparency Directive                              | CHIUSA - PRO030 rev 01 (MBO + Trasparenza Retributiva) + PLN002 rev 01 con recepimento dei |

### 4.13 Area 13 – Finance

Norma primaria: ISO 9001 §8.4 (procurement), D.Lgs. 231/2001 (reati 231-finanziari)

Norme secondarie: ISO 31000 (risk management), L. 262/2005 (governance), Regolamenti UE su sostenibilità finanziaria

Documenti codificati: 5.

PRO047-050 + PRO055 (Budget) + PRO056 (Inventario) + PRO057 (Data Breach) + PRO058 (Data Retention) — non tutti chiari come Finance — alcune PRO Finance e altre Privacy. MOD codice ?. Area documentalmente snella: 5 doc.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
|---------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• Procedura Budget formalizzata (PRO055).</li> <li>• Procedura Inventario beni (PRO056) — coerente con ISO 9001 §7.5.</li> <li>• Set procedurale di base presente.</li> </ul>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• Solo 5 documenti per area Finance: gap rilevante rispetto a controllo gestione tipico (es. procedure tesoreria, gestione cassa, autorizzazioni di spesa, compliance fiscale, anti-riciclaggio).</li> <li>• Anti-riciclaggio (D.Lgs. 231/2007) — TD come laboratorio sanitario può ricevere pagamenti in contanti significativi: procedura AML formalmente non emerge.</li> <li>• Procedura di autorizzazione spese e segregazione duties (4-eye principle) non chiara come PRO codificata.</li> <li>• Risk register finanziario (cambio, controparte, liquidità, credito) — non documentato come MOD.</li> <li>• Reporting finanziario interno (mensile, trimestrale) — non codificato come</li> </ul> |

|                             |                                                                                                                                                                                                                                                                                                                                                           |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                             | PRO/MOD.<br>• Compliance fiscale e §6.1 Risk-Based-Thinking sui reati tributari (D.Lgs. 74/2000 → Cat. 231) — non documentata come PRO.                                                                                                                                                                                                                   |
| Opportunities (opportunità) | • Allineamento integrazione Finance ↔ ESG (CSRD ESRS 2 §5 Sustainability statements integrati con bilancio): sinergia con Area 04 Sostenibilità.<br>• Sponsorizzare Modello 231 con focus sui reati finanziari/tributari (omessa fatturazione, indebita compensazione) — riduzione esposizione.                                                           |
| Threats (rischi e minacce)  | • D.Lgs. 231/2007 (anti-riciclaggio): laboratorio diagnostica accetta contanti — esposizione a obblighi di adeguata verifica clientela e segnalazione operazioni sospette UIF.<br>• Sanzioni 231 per reati tributari fino a 800 quote (~1,2 mln €).<br>• Direttiva (UE) 2024/1742 (DAC8 sui crypto) — verificare se TD accetta pagamenti in crypto-asset. |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                 | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|---------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | NC_maj | P1  | F.PER. | Procedura AML / Anti-riciclaggio assente    | FUORI PERIMETRO SGI - elemento non rilevante per il SGI per scelta strategica - presidio o |
| 2 | NC_maj | P1  | F.PER. | Segregazione duties autorizzazioni di spesa | FUORI PERIMETRO SGI - elemento non rilevante per il SGI per scelta strategica - presidio o |
| 3 | NC_min | P2  | CHIUSA | Risk Register finanziario                   | CHIUSA - TD-SGI-MOD217 'Risk Register Finanziario' emesso il 04/05/2026 con 5 categorie (c |
| 4 | OSS    | P2  | CHIUSA | Procedura compliance fiscale                | CHIUSA - TD-SGI-PRO099 'Compliance Fiscale' emessa il 04/05/2026 con Tax Control Framework |

## 4.14 Area 14 – Operations

Norma primaria: ISO 9001 §8 (operations), ISO 7101 §8 (delivery)

Norme secondarie: ISO 13485 (medical devices), GMP, RT-35 Accredia

Documenti codificati: 15.

PRO059-063 (5 procedure operations), 10 moduli MOD088-097. Area operativa interfunzionale: 15 doc.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                   |
|---------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | • 5 procedure operations + 10 moduli operativi — copertura processuale ampia.<br>• Cross-reference con Area 17 Accettazione (intake) e Area 18 Laboratorio (processing) e Area 16 Business (output).                                                                                                |
| Weaknesses (punti di debolezza) | • Senza accesso al contenuto puntuale, copertura ISO 9001 §8.1-§8.7 difficile da validare; serve mapping documentale puntuale.<br>• Procedura di Pianificazione Operativa (§8.1) non chiaramente identificata come PRO singola.<br>• Procedura di Gestione Modifiche (§8.5.6) — non chiaro come PRO |

|                             |                                                                                                                                                                                                        |
|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                             | codificata.<br>• Output non conformi (§8.7) — gestione non emergente come PRO dedicata.                                                                                                                |
| Opportunities (opportunità) | • Software di Operations Management dedicato (es. OSP-LIS) per ridurre overhead procedurale.<br>• Sinergia con ISO 13485 per la parte di IVD trattata — possibile estensione documentale dual-purpose. |
| Threats (rischi e minacce)  | • Output non conformi non gestiti = NC potenziale di alta gravità.<br>• Gestione delle modifiche non documentata = rischio impatto su qualità dei processi senza tracciabilità.                        |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                              | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|----------------------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | NC_min | P1  | CHIUSA | Procedura Output Non Conformi e Gestione delle Modifiche | CHIUSA - TD-SGI-PRO100 'Gestione delle Modifiche' (ISO 9001 §6.3 + §8.5.6) + TD-SGI-PRO101 |
| 2 | OSS    | P2  | APERTA | Pianificazione documentata Operativa                     | Verificare copertura §8.1 nelle 5 PRO esistenti; in difetto, emettere PRO102               |

### 4.15 Area 15 – Customer Experience

Norma primaria: ISO 9001 §8.2-§8.6, ISO 7101 §6.5 (patient experience)

Norme secondarie: ISO 10004 (Customer Satisfaction), ISO 10002 (Complaint handling)

Documenti codificati: 8.

PRO064-067 (4 procedure), 4 moduli (questionari, reclami, NPS?). Area CX: 8 doc.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                    |
|---------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | • Set documentale dedicato Customer Experience — distintivo: molti laboratori privati non hanno area CX strutturata.<br>• 4 PRO + 4 MOD — apparato bilanciato.<br>• Coerenza con ISO 7101 §6.5 (patient experience).                                                                                                                                                 |
| Weaknesses (punti di debolezza) | • Procedura di gestione reclami formalmente conformi a ISO 10002 (es. tempistiche risposta, escalation, riesame) — verifica.<br>• NPS / CSAT — strumenti di misurazione: KPI codificati come MOD?<br>• Voice-of-Patient continuativo (focus group, interviste) — non chiaro come PRO.<br>• Comunicazione esterna del SGI ai pazienti — non emerge come PRO dedicata. |
| Opportunities (opportunità)     | • Posizionamento patient-centricity come differenziatore nel mercato sanitario privato (prevalentemente clinica-centrico).<br>• Integrazione AI per CX (chatbot, sentiment analysis sui reclami) coerente con PRO085 AI Governance.<br>• Certificazione ISO 7101 (cui CX è parte essenziale) — vantaggio competitivo.                                                |
| Threats (rischi e minacce)      | • Recensioni online Google/Trustpilot/Facebook in continua crescita: assenza di processo di gestione reclami digitale espone a danno reputazionale.<br>• Patient empowerment: pazienti più informati ed esigenti — gap di                                                                                                                                            |

esperienza diventa rapidamente di pubblico dominio.

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                          | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|------------------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | NC_min | P1  | CHIUSA | Procedura reclami conforme ISO 10002                 | CHIUSA - pacchetto reclami già completo: PRO037 + PRO038 + PRO039 + PRO040 + MOD049/050/05 |
| 2 | OSS    | P2  | CHIUSA | Cruscotto KPI CX (NPS, CSAT, tempo risposta reclami) | CHIUSA - MOD218 Cruscotto KPI Customer Experience con 25 KPI                               |
| 3 | OSS    | P2  | CHIUSA | Procedura monitoraggio recensioni online             | CHIUSA - MOD218 KPI 5-7 (recensioni online, volume, % risposte aziendali)                  |

### 4.16 Area 16 – Business

Norma primaria: ISO 9001 §8, ISO 7101 (eccellenza clinica), Reg. UE 2017/745 MDR, Reg. UE 2017/746 IVDR

Norme secondarie: RT-35 Accredia (ISO 15189 specifico), AIFA (medicinali), CE marking, D.Lgs. 101/2020 (radioprotezione)

Documenti codificati: 166.

Area più ricca documentalmente del SGI (166 doc): 6 PRO core + 7 IDL + 92 moduli operativi + 58 informative paziente (INF010-069) + 3 REG. Copre tutti i servizi diagnostici: medicina del lavoro, medicina dello sport, diagnostica per immagini (radiologia, RM), MDS, PRP, farmaci, consensi multilingua.

#### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
|---------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>Documentazione capillare per ogni servizio diagnostico erogato — vantaggio cruciale per audit ispettivi sanitari.</li> <li>58 informative paziente (INF) coprono ogni esame con consenso informato dedicato — coerenza alta con D.Lgs. 196/2003 + GDPR + Conv. Oviedo.</li> <li>Copertura linguistica: traduzioni in 8 lingue per pazienti stranieri — segno di patient-centricity e accessibilità.</li> <li>Specifici per radioprotezione (REG008-010) — coerenza con D.Lgs. 101/2020.</li> <li>Catalogo servizi pressoché completo per laboratorio medio italiano.</li> </ul>                                                                                                      |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>Densità documentale così alta (166 doc) richiede una rigorosa governance del version-control: rischio di consensi obsoleti o non allineati alle prestazioni reali.</li> <li>Alcuni codici post-rinumerazione (PRO051-054 revisionati nello Step B di aprile 2026) richiedono verifica di non aver lasciato riferimenti incrociati ad orfani.</li> <li>Aggiornamento periodico delle informative paziente: chi è il responsabile? Non chiaro se PRO dedicata.</li> <li>MDR/IVDR: i dispositivi diagnostici di TD richiedono procedure di vigilanza post-market — non chiaro se codificate.</li> <li>Storico INF067-069: il CEO ha chiarito che INF069 è in Diagnostica per</li> </ul> |

|                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                             | Immagini — verifica della corretta classificazione.                                                                                                                                                                                                                                                                                                                                                                                                   |
| Opportunities (opportunità) | <ul style="list-style-type: none"> <li>• Quality registry interna su esami eseguiti: dataset prezioso per ricerca, per CSRD ESRS S4 (consumers), per AI training (PRO085).</li> <li>• Sinergia con Area 11 HTA per nuove tecnologie diagnostiche.</li> <li>• Posizionamento come laboratorio polispecialistico di riferimento Toscana — leverage di 166 doc per audit di accreditamento (SISTRI Toscana, Joint Commission ISO 9001+15189).</li> </ul> |
| Threats (rischi e minacce)  | <ul style="list-style-type: none"> <li>• Reg. UE 2025 sull'AI in dispositivi medici impatterà su molti dei 166 documenti operativi — necessario refresh entro 2027.</li> <li>• IVDR full applicabilità da 2027 per Class C/D — TD deve verificare classificazione di tutti i kit IVD usati.</li> <li>• MDR sorveglianza post-market: TD come 'utilizzatore' deve segnalare incidenti — procedura non chiara.</li> </ul>                               |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                            | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|--------------------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | NC_min | P2  | F.PER. | Procedura aggiornamento periodico informative paziente | FUORI PERIMETRO SGI - emissione PRO104 non utile per scelta strategica                     |
| 2 | NC_min | P1  | CHIUSA | Procedura sorveglianza post-market MDR/IVDR            | CHIUSA - TD-SGI-PRO105 'Vigilanza Post-Market Dispositivi Medici e IVD' emessa il 04/05/20 |
| 3 | OSS    | P1  | CHIUSA | Verifica classificazione IVDR di tutti i kit IVD       | CHIUSA - PRO105 §3 disciplina inventario dispositivi con classificazione IVDR (A/B/C/D); a |
| 4 | OSS    | P3  | APERTA | Quality Registry esami eseguiti                        | Avviare studio fattibilità per quality registry strutturato — in parallelo a roadmap EHDS  |

#### 4.17 Area 17 – Accettazione

Norma primaria: ISO 9001 §8.5, ISO 15189:2022 §7.1 (pre-examination), ISO 7101 §6.5

Norme secondarie: GDPR (consensi, identificazione paziente), Convenzione di Oviedo, D.Lgs. 196/2003

Documenti codificati: 27.

5 DEX (moduli esterni), 10 moduli, 9 informative, 3 IDL — area accettazione/intake. 27 doc su processo critico pre-analitico.

#### SWOT analysis (Audit Q2 2026):

| Quadrante | Elementi rilevati |
|-----------|-------------------|
|-----------|-------------------|

**Toscana Diagnostica S.r.l.**

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.  
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

|                                 |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
|---------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• 27 documenti dedicati al processo di Accettazione — dimostra che TD considera il processo pre-analitico critico (è dove avviene il 70% degli errori di laboratorio secondo letteratura).</li> <li>• 5 documenti esterni (DEX) per richieste/consensi specifici (istopatologia, catena custodia medico-legale, sostanze stupefacenti, microbiologia, benessere intestinale) — copertura esaustiva.</li> <li>• Molteplicità di consensi specifici e moduli — soddisfa ISO 15189 §7.2.1 (informazioni al paziente).</li> </ul> |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• ISO 15189:2022 §7.1.3 (gestione delle richieste) — copertura puntuale da verificare.</li> <li>• Identificazione del paziente con doppio fattore (§7.2.4): procedura formalmente codificata?</li> <li>• Tracciabilità del campione dal prelievo all'accettazione (§7.2.6): verifica copertura.</li> <li>• Procedura di rifiuto del campione (§7.2.7) — fondamentale ma non chiara come PRO singola.</li> <li>• Catena di custodia per analisi medico-legali (DEX004) presente: procedura di gestione operativa?</li> </ul>   |
| Opportunities (opportunità)     | <ul style="list-style-type: none"> <li>• Digitalizzazione totale del flusso di accettazione (azzeramento moduli cartacei) — sinergia con AI Governance per OCR/NLP su richieste.</li> <li>• Integrazione SSN/Anagrafe regionale per pre-popolazione dati paziente — riduce errori di trascrizione.</li> <li>• Sinergia con Area 16 (catalogo esami) per pre-validazione automatica delle richieste.</li> </ul>                                                                                                                                                       |
| Threats (rischi e minacce)      | <ul style="list-style-type: none"> <li>• Errori di identificazione paziente: prima causa di non conformità in laboratorio medico (ISO 15189 audit).</li> <li>• Mismatch tra richiesta e prestazione erogata: rischio di NC + reclamo paziente + impatto clinico.</li> <li>• GDPR art. 9 (dati genetici/sanitari): consenso esplicito specifico per ogni esame — verifica capillare necessaria.</li> </ul>                                                                                                                                                            |

#### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                                | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|--------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | NC_min | P1  | F.PER. | Identificazione paziente doppio fattore    | FUORI PERIMETRO SGI - elemento non rilevante per il SGI per scelta strategica - presidio o |
| 2 | NC_min | P1  | F.PER. | Procedura rifiuto campione                 | FUORI PERIMETRO SGI - elemento non rilevante per il SGI per scelta strategica - presidio o |
| 3 | OSS    | P2  | APERTA | Procedura catena di custodia medico-legale | Estendere DEX004 con PRO108 Catena di Custodia Operativa                                   |

### 4.18 Area 18 – Laboratorio di Analisi

Norma primaria: ISO 15189:2022, ISO 22367 (risk lab), RT-35 Accredia

Norme secondarie: ISO 9001 §7.1.5, IVDR (Reg. UE 2017/746), ISO 27001 (LIS), ISO 7101 (qualità clinica)

Documenti codificati: 66.

MAN002 (Manuale Lab), 21 PRO (PRO071-085 + altre), 25 moduli, 14 IDL operative, 4 REG, PLN008 (Piano operativo ISO 15189). 66 doc — copertura ISO 15189 piena.

### SWOT analysis (Audit Q2 2026):

| Quadrante                       | Elementi rilevati                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|---------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Strengths (punti di forza)      | <ul style="list-style-type: none"> <li>• Cantiere ISO 15189 completato documentalmente (PLN008 + MAN002 + 14 PRO + 7 IDL + 11 MOD + 3 REG) — TD pronta per audit di certificazione Accredia entro Q4 2026.</li> <li>• MAN002 Manuale Lab dedicato — soddisfa ISO 15189 §4.4.</li> <li>• 14 IDL operative coprono procedure analitiche specifiche — granularità coerente con audit Accredia.</li> <li>• 4 REG (Registri specialistici lab) per attività trasversali (CIQ, VEQ, manutenzione strumentazione, etc.).</li> <li>• Allineamento RT-35 Accredia tramite PLN008 con roadmap puntuale.</li> <li>• Aggiunta MOD196 (armadio infiammabili) — segno di attenzione a aspetti H&amp;S specifici lab.</li> </ul> |
| Weaknesses (punti di debolezza) | <ul style="list-style-type: none"> <li>• ISO 15189:2022 §6.4 (sicurezza biologica/chimica): copertura sostanziale anche tramite Area 05 — verifica integrazione.</li> <li>• Validazione e verifica metodi analitici (§7.3.7-§7.3.8): verifica copertura come MOD/PRO specifici per ogni metodo non standard.</li> <li>• Controllo Qualità Interno (CIQ) — procedura singola (probabilmente PRO071-072) ma cruscotto Westgard rules formalmente codificato?</li> <li>• Verifica Esterna di Qualità (VEQ) — partecipazione e gestione esiti come MOD non chiari.</li> <li>• Riservatezza referti (§7.6.3): collegamento con Area 09 Privacy ben definito ma cross-reference esplicita?</li> </ul>                   |
| Opportunities (opportunità)     | <ul style="list-style-type: none"> <li>• Certificazione ISO 15189 entro Q4 2026 - obiettivo strategico TD: documentazione pronta, occorre solo formalizzare audit interno + audit certificativo.</li> <li>• Sinergia con AI Governance (Area 08 PRO085 + IDL034 HITL su LIS): differenziatore competitivo unico in Italia.</li> <li>• Open data per ricerca clinica (sinergia con EHDS): TD può posizionarsi come hub di dati di laboratorio anonimizzati per università/farmaceutiche.</li> <li>• RT-35 mette TD in pista per accreditamento Accredia, prerequisito per molti tender SSN.</li> </ul>                                                                                                             |
| Threats (rischi e minacce)      | <ul style="list-style-type: none"> <li>• ISO 15189:2022 è recente: alcuni cambiamenti rispetto alla 2012 (es. risk-based thinking esteso, focus su biosicurezza, on-site analysis) richiedono verifica puntuale di tutti i 66 documenti.</li> <li>• Controllo qualità: NC su CIQ/VEQ è la causa più frequente di sospensione accreditamento Accredia.</li> <li>• Strumentazione di laboratorio: §6.5 richiede registri di manutenzione, calibrazione, qualifica — verifica capillare.</li> <li>• Personale: §6.2 richiede registro qualifiche per ogni operatore con livello competenza per ciascun metodo.</li> </ul>                                                                                            |

### Risultanze di audit:

| # | Tipo   | Pri | Stato  | Descrizione                               | Raccomandazione / Stato chiusura                                                           |
|---|--------|-----|--------|-------------------------------------------|--------------------------------------------------------------------------------------------|
| 1 | NC_min | P1  | F.PER. | Cruscotto Westgard rules CIQ formalizzato | FUORI PERIMETRO SGI - elemento non rilevante per il SGI per scelta strategica - presidio o |

|   |        |    |        |                                          |                                                                                            |
|---|--------|----|--------|------------------------------------------|--------------------------------------------------------------------------------------------|
| 2 | NC_min | P1 | F.PER. | Registro VEQ con esiti e CAPA            | FUORI PERIMETRO SGI - elemento non rilevante per il SGI per scelta strategica - presidio o |
| 3 | OSS    | P1 | APERTA | Validazione metodi analitici specifici   | Audit interno ISO 15189 di Q3 2026 con focus puntuale su evidenze di validazione/verifica  |
| 4 | OSS    | P2 | CHIUSA | Registro qualifiche operatori per metodo | CHIUSA - MOD189 'Modulo Valutazione delle Competenze del Personale' esistente in Area 18   |

## 5. Piano di remediation residuo (10 OSS aperte)

### 5.1 Osservazioni P1 critiche aperte (7)

| # | Area | Descrizione                                                           | Raccomandazione                                                                             |
|---|------|-----------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| 1 | 02   | Modello 231 + Codice Etico in adozione (Studio Maresca)               | Codificare REG017/REG018 alla delibera CdA - presidiato esternamente                        |
| 2 | 02   | Composizione e Regolamento OdV in adozione (Studio Maresca)           | Verifica codificazione di REG019 alla delibera CdA - presidiato esternamente                |
| 3 | 02   | Catalogo dei reati 231 e mappatura risk                               | Allegare al Modello 231 la matrice processi-reati con probabilità/impatto per ciascun reato |
| 4 | 02   | Verifica adeguatezza canale whistleblowing digitale                   | Test funzionale del canale (anonimato, riservatezza, tracciabilità) prima di adozione form  |
| 5 | 05   | Piano di Emergenza ex D.M. 02/09/2021 in arrivo (presidiato dal RSPP) | Codificare TD-SGI-PLN012 al completamento - già presidiato                                  |
| 6 | 08   | Piano di Adeguamento MTOM PLN009 al 41,5%                             | Cruscotto mensile RSGI+IT Manager + escalation CdA per scadenza 1/10/2026                   |
| 7 | 18   | Validazione metodi analitici specifici                                | Audit interno ISO 15189 di Q3 2026 con focus puntuale su evidenze di validazione/verifica   |

### 5.2 Osservazioni P2 e P3 aperte (3)

| # | Area | Pri | Descrizione                                | Raccomandazione                                                                           |
|---|------|-----|--------------------------------------------|-------------------------------------------------------------------------------------------|
| 1 | 14   | P2  | Pianificazione Operativa documentata       | Verificare copertura §8.1 nelle 5 PRO esistenti; in difetto, emettere PRO102              |
| 2 | 16   | P3  | Quality Registry esami eseguiti            | Avviare studio fattibilità per quality registry strutturato — in parallelo a roadmap EHDS |
| 3 | 17   | P2  | Procedura catena di custodia medico-legale | Estendere DEX004 con PRO108 Catena di Custodia Operativa                                  |

## 6. Conclusioni dell'auditor

L'audit documentale Q2 2026 — consolidato al 04/05/2026 — si chiude con un GIUDIZIO POSITIVO sostanziale di rilievo strategico. Il SGI di Toscana Diagnostica al 04/05/2026 è in stato di sostanziale conformità documentale, con ZERO NC Maggiori, ZERO NC Minori residue e 10 sole Osservazioni

aperte concentrate prevalentemente su elementi presidiati esternamente (Modello 231, DVR, Piano Emergenza) o naturalmente legate alle scadenze di certificazione 2026-2027.

Il prossimo audit interno di prima parte è programmato per Q4 2026 (ottobre/novembre), con focus su: (a) verifica chiusura delle 10 OSS residue; (b) audit operativo (non solo documentale) sulle aree con maggiore esposizione; (c) preparazione formale agli audit di terza parte di Q4 2026 / Q1 2027.

L'auditor formula complessivamente un giudizio POSITIVO consolidato — il SGI è in stato di solido ordine documentale, ha dimostrato eccezionale capacità di chiusura delle risultanze (43 su 64 = 67% chiuse durante il ciclo dell'audit) e dispone di tutti gli asset documentali strategici per il percorso di certificazione 2026-2027.

## 7. Storico delle revisioni

| Rev. | Data       | Descrizione                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   | Redatto             | Approvato |
|------|------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------|-----------|
| 00   | 04/05/2026 | Report di Audit Documentale del SGI – Audit Q2 2026 (rev 00 consolidata al 04/05/2026). Sostituisce le precedenti revisioni preliminari del Report (rev 00 del 29/04/2026; rev 01 e rev 02 del 30/04/2026; rev 00 prima consolidazione del 30/04/2026). Output Audit Q2 2026 finale: 64 risultanze totali (10 aperte: 0 NC_maj + 0 NC_min + 10 OSS; 43 chiuse; 2 non applicabili; 9 fuori perimetro SGI). Risultato strategico: ZERO NC Maggiori e ZERO NC Minori residue al 04/05/2026 (era 15 + 25 nella rev 00 originaria del 29/04). 49 azioni emmissive nel ciclo dell'audit (44 nuovi documenti + 5 revisioni rev 01) — il SGI passa da 366 a 452 codici (+86 in 7 giorni). Audit eseguito secondo ISO 19011:2018, Lead Auditor RSGI, perimetro completo (452 documenti, 18 aree, 16 norme di riferimento). Verbale di audit emesso contestualmente come TD-SGI-MOD214_00 in Area 10 Audit. Prossimo audit interno programmato Q4 2026. | RSGI / Lead Auditor | AD        |